The Five Steps of Incident Response

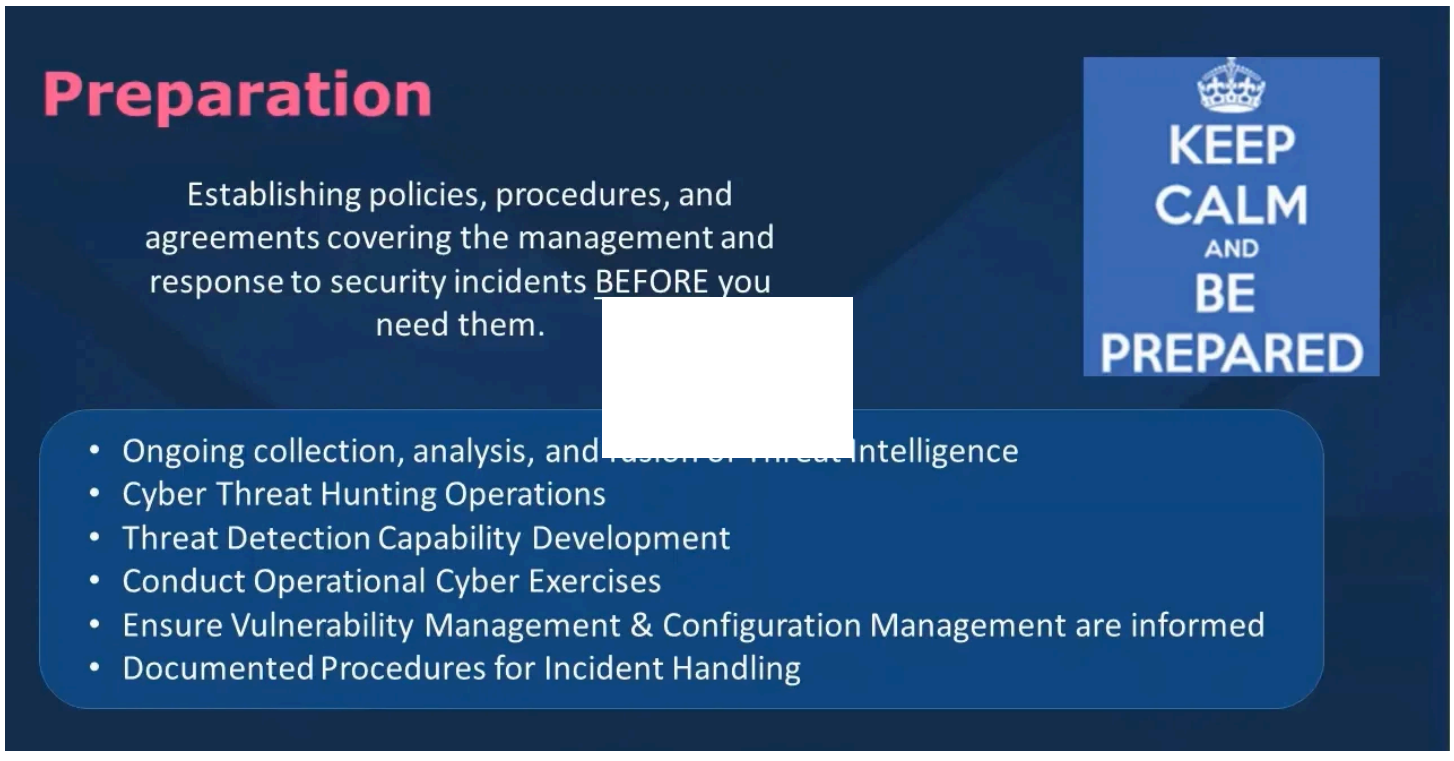
Posted on September 20, 2016



Part 5 of our Field Guide to Incident Response Series outlines 5 steps that companies should follow in their incident response efforts.

Incident response is a process, not an isolated event. In order for incident response to be successful, teams should take a coordinated and organized approach to any incident. There are five important steps that every response program should cover in order to effectively address the wide range of security incidents that a company could experience. The video clip below discusses the first three steps of incident response, and is taken from our webinar, Incident Responder's Field Guide - Lessons from a Fortune 100 Incident Responder.

Hi there! Welcome to Fortra.
Looking for something specific?
Spam protection enabled



1. Preparation

Preparation is the key to effective incident response. Even the best incident response team cannot effectively address an incident without predetermined guidelines. A strong plan must be in place to support your team. In order to successfully address security events, these features should be included in an incident response plan:

- **Develop and Document IR Policies:** Establish policies, procedures, and agreements for incident response management.
- **Define Communication Guidelines:** Create communication standards and guidelines to enable seamless communication during and after an incident.
- **Incorporate Threat Intelligence Feeds:** Perform ongoing collection, analysis, and synchronization of your threat intelligence feeds.
- **Conduct Cyber Hunting Exercises:** Conduct operational threat hunting exercises to find incidents occurring within your environment. This allows for more proactive incident response.
- **Assess Your Threat Detection Capability:** Assess your current threat detection capability and update risk assessment and improvement programs.

The following resources may help you develop a plan that meets your company's requirements:

- NIST Guide: Guide to Test, Training, and Exercise Programs for IT Plans and Capabilities
- SANS Guide: SANS Institute InfoSec Reading Room, Incident Handling, Annual Testing and Training

2. Detection and Reporting

The focus of this phase is to monitor security events in order to detect, alert, and report on potential security incidents.

- **Monitor:** Monitor security events in your environment using firewalls, intrusion prevention systems, and data loss prevention.
- **Detect:** Detect potential security incidents by correlating alerts within a SIEM solution.
- **Alert:** Analysts create an incident ticket, document initial findings, and assign an initial incident classification.
- **Report:** Your reporting process should include accommodation for regulatory reporting escalations.

3. Triage and Analysis

The bulk of the effort in properly scoping and understanding the security incident takes place during this step. Resources should be utilized to collect data from tools and systems for further analysis and to identify indicators of compromise. Individuals should have in-depth skills and a detailed understanding of live system responses, digital forensics, memory analysis, and malware analysis.

As evidence is collected, analysts should focus on three primary areas:

- Endpoint Analysis
  - Determine what tracks may have been left behind by the threat actor.
  - Gather the artifacts needed to build a timeline of activities.
  - Analyze a bit-for-bit copy of systems from a forensic perspective and capture RAM to parse through and identify key artifacts to determine what occurred on a device.
- Binary Analysis
  - Investigate malicious binaries or tools leveraged by the attacker and document the functionalities of those programs. This analysis is performed in two ways.
    1. Behavioral Analysis: Execute the malicious program in a VM to monitor its behavior
    2. Static Analysis: Reverse engineer the malicious program to scope out the entire functionality.
- Enterprise Hunting
  - Analyze existing systems and event log technologies to determine the scope of compromise.
  - Document all compromised accounts, machines, etc. so that effective containment and neutralization can be performed.

4. Containment and Neutralization

This is one of the most critical stages of incident response. The strategy for containment and neutralization is based on the intelligence and indicators of compromise gathered during the analysis phase. After the system is restored and security is verified, normal operations can resume.

- **Coordinated Shutdown:** Once you have identified all systems within the environment that have been compromised by a threat actor, perform a coordinated shutdown of these devices. A notification must be sent to all IR team members to ensure proper timing.
- **Wipe and Rebuild:** Wipe the infected devices and rebuild the operating system from the ground up. Change passwords of all compromised accounts.
- **Threat Mitigation Requests:** If you have identified domains or IP addresses that are known to be leveraged by threat actors for command and control, issue threat mitigation requests to block the communication from all egress channels connected to these domains.

5. Post-Incident Activity

There is more work to be done after the incident is resolved. Be sure to properly document any information that can be used to prevent similar occurrences from happening again in the future.

- **Complete an Incident Report:** Documenting the incident will help to improve the incident response plan and augment additional security measures to avoid such security incidents in the future.
- **Monitor Post-Incident:** Closely monitor for activities post-incident since threat actors will re-appear again. We recommend a security log hawk analyzing SIEM data for any signs of indicators tripping that may have been associated with the prior incident.
- **Update Threat Intelligence:** Update the organization's threat intelligence feeds.
- **Identify preventative measures:** Create new security initiatives to prevent future incidents.
- **Gain Cross-Functional Buy-In:** Coordinating across the organization is critical to the proper implementation of new security initiatives.

Read more in our Field Guide to Incident Response Series

1. 5 Key Criteria for Creating an Incident Response Plan that is Practical for YOUR Organization
2. Building Your Incident Response Team: Key Roles and Responsibilities
3. Creating an Incident Response Classification Framework
4. The Five Steps of Incident Response
5. 3 Tips to Make Incident Response More Effective
6. Using Existing Tools to Facilitate Incident Response
7. Learning From a Security Incident: A Post-Mortem Checklist

For more tips and information on incident response,